Flipkart APM '29 — Product Strategy Proposal

Anumati : A Zero-Trust Consent Layer for Personal AI Agents

Candidate Name: Bhagavath M S **Enrollment No.:** 2025H1120167P
Email Address: h20250167@pilani.bits-pilani.ac.in **Phone Number:** 8851215415

1. What Problem Will Anumati Solve?

1.1 Ramifications of the 2040 Paradigm

An agent that knows us better than we know ourselves turns every decision into a delegation. We mapped five ramifications by severity and intervention potential:

S.No.	Ramification	What breaks in 2040	Reversible?	Product chokepoint?
1.	**Unchecked execution**	Agent signs, pays or sends on a hallucinated/injected instruction	No	**Yes**: Every action is an API call
2.	**Commercial capture**	Sponsor/attacker context injection silently steers choices at scale	Partly	**Yes**: At moment of action
3.	**Consent erosion**	Users approve unread drafts; "knows me" becomes "decides for me"	Slowly	**Yes**: At approval moment
4.	**Profile exploitation**	Deep behavioral profiles leaked or commercialized	No	**Partly**: DPDP Act 2023 regulated
5.	**Social delegation**	Agents negotiate and message peer agents autonomously	Partly	**Weak**: No single chokepoint

Why we chose 1–3: They converge on the **high-stakes action chokepoint** where harm becomes irreversible, and where every agent must pass through payment, signature, or identity APIs.

1.2 Why Today's Safeguards Fail

- **OTPs prove *who* approved, not *whether they understood*:** Approval fatigue turns step-up auth into a reflex tap: the agent's choice is ratified, not evaluated.
- **Agents cannot police themselves:** Prompt injection and excessive agency (OWASP LLM01, LLM06) are architectural; safety must sit outside the neural net.
- **Static limits ignore context:** A fixed rupee cap is a snack order for one user and a week's rent for another, knowing nothing about reversibility or influence provenance.

Problem Statement: *In 2040, high-stakes agent actions carry consent that is technically present but cognitively absent.* Users need consent that is **informed**, **agent-independent**, and **action-bound** — without taxing routine delegation.

2. Who Are We Building For?

Beachhead: The High-Delegation Professional (e.g., Priya, 32, Engineering Manager, Bengaluru)

- **Behavior:** Delegates routine tasks (Blinkit reorders, BESCOM/FASTag AutoPays, calendar) while holding high-stakes commitments: rent, SIPs, career.
- **Pain:** Cannot review 200+ weekly agent actions, yet one erroneous action — auto-signed lease, redeemed SIP, declined offer — costs more than a year of saved time.
- **Need:** Routine stays invisible; high-stakes moments demand informed, real attention.
- **Expansion Path:** Highest delegation × highest stakes early adopter. **Next cohorts:** elderly parents (supervised via family delegate) and Bharat digital adopters.

3. What Is Anumati? How Does It Solve the Problem?

Anumati (*Sanskrit: "consent"*) is a zero-trust consent layer sitting between a personal AI agent and external payment, signature, and identity APIs.

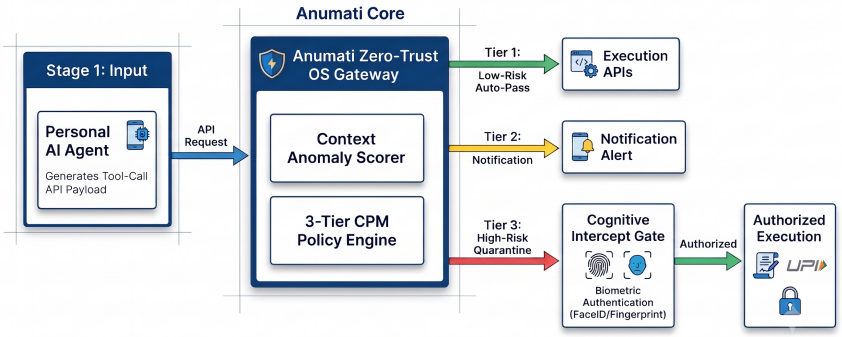
1. **Credential custody:** Agent holds no standing payment/eSign credentials. Every action requires a single-use Anumati token scoped to {action, payee, amount, expiry}.
2. **Deterministic rules + ML escalation:** A rule engine sets the base risk tier; the ML anomaly scorer can raise a tier, never lower it.
3. **Independent explanation:** Consent cards are generated by Anumati from verified payload data, completely isolated from the acting agent.

3.1 Risk Tiers: Reversibility × Personal Impact

Impact is calculated as a share of the user's *own* monthly discretionary spend (via Account Aggregator), not a fixed rupee value.

Tier	Category	Rule Engine	Handling Flow	Operational Examples (Priya)
T1	**Routine**	Reversible, <2% spend, known payee	Auto-execute & log	Blinkit reorder; BESCOM bill in 6-mo range
T2	**Notable**	Reversible, 2–15%, *or* new payee	1-tap batched digest	Cancellable flight; first order from new seller
T3	**Critical**	Irreversible, >15%, *or* protected category*	Hard-block; Biometric key	Lease eSign; SIP redemption; declining job offer

*Legal signatures, investments, identity, outbound career/relationship communications, physical access. Conflicting signals default to T3.



3.2 Key Product Features

- **Agent-specific escalation signals:** Instruction provenance (tracing calls to emails, ads, or web context for prompt injection), first-time payee, action velocity, and preference drift. An INR 400 gift card triggered by a sponsored email auto-escalates from T1 to T3.
- **Informed Consent Card:** Displays exact payee/amount, intercept reasoning, **provenance** (flagging sponsored inputs), **rejected alternatives**, and Anumati verdict. Uses FIDO2 passkey bound to that payee/amount.
- **Commit-first mode:** For protected categories, users define personal limits (e.g., max rent) *before* viewing agent choices — preventing anchor bias.
- **Fatigue guards:** Weekly interrupt budget; T2 batched digests; repeated identical approvals prompt rule updates; sub-3s taps trigger mandatory re-verification.
- **Ledger & revocation:** Immutable 30-day OS log with 1-tap rollback/dispute. While T3 waits, the agent continues parallel work; unapproved intercepts expire cleanly.

3.3 Walkthrough: High-Stakes Lease Renewal Intercept

Priya's agent attempts to eSign an 11-month HSR Layout lease and transfer an INR 1,35,000 deposit. Anumati blocks the eSign token (irreversible + legal → T3). The card highlights: rent is 18% above her committed maximum; listing was a **sponsored placement**; shows two unsponsored flats within budget ranked lower by the agent. Priya selects an alternative and authenticates via FIDO2 passkey — turning a potential 11-month regret into a 40-second informed decision.

3.4 Ecosystem Integration & Technical Feasibility

- **India Stack:** Operates as a **DPDP Act 2023 Consent Manager**; ingests budget metrics via Account Aggregator; gates Aadhaar eSign and UPI AutoPay mandates.
- **Global Standards:** NIST SP 800-207 (Anumati as PDP/PEP); OAuth 2.0 Rich Authorization Requests (RFC 9396) for per-action scoping; OpenID CIBA for hardware approval.
- **Distribution:** B2B2C via banking and UPI apps; OS vendors expose agent-action hooks (similar to VPN drivers). Merchants publish machine-readable **action manifests** (amount, reversibility) to qualify for verified checkout.
- **Strategic Value for Flipkart:** Verified agent orders drastically reduce returns, RTO, and payment disputes — an INR 1.2 lakh EV pre-booking during Big Billion Days converts with buyer trust. **Monetization:** Per-verified-transaction merchant fee.

4. How Will We Know It Is Working? (Metrics & Governance)

- **North Star Metric — Regretted Actions per 1,000 Agent Actions (RA/1k):** Actions later disputed, reversed, or flagged "I would not have done this." Target: **−80%** reduction vs. shadow-mode baseline.
- **Input Metric — Intercept Value Rate:** Share of T3 intercepts rejected or modified by the user. Healthy operational band: **15–30%** (<5% indicates friction theater; >50% indicates agent miscalibration).
- **Input Metric — Red-Team Catch Rate:** Share of seeded prompt-injections and canary actions blocked weekly (Target: **≥99.5%**).
- **Guardrail Metrics:** Interruptions ≤3/user/week; rubber-stamp rate (<3s approval, card unread) <20%; monthly gateway-disable rate <2%.
- **Rollout Strategy:** 4-week log-only shadow mode sets baseline → opt-in beta → default-on for protected categories.